INTRODUCTION A LA SECURITE INFORMATIQUE

Présenté par ***: Charbel ACHADE***

Plan

Introduction

Module 1 : Introduction à la sécurité informatique

Module 2 : Les objectifs de la sécurité informatique

Modules 3 : Les champs d'application de la sécurité informatique

Modules 4 : Terminologie de la sécurité informatique

Modules 5 : Types d'attaques

Modules 6 : Profils et capacités des attaquants

Modules 7 : Services principaux de la securité informatique

Modules 8 : Hacking Ethique

Conclusion

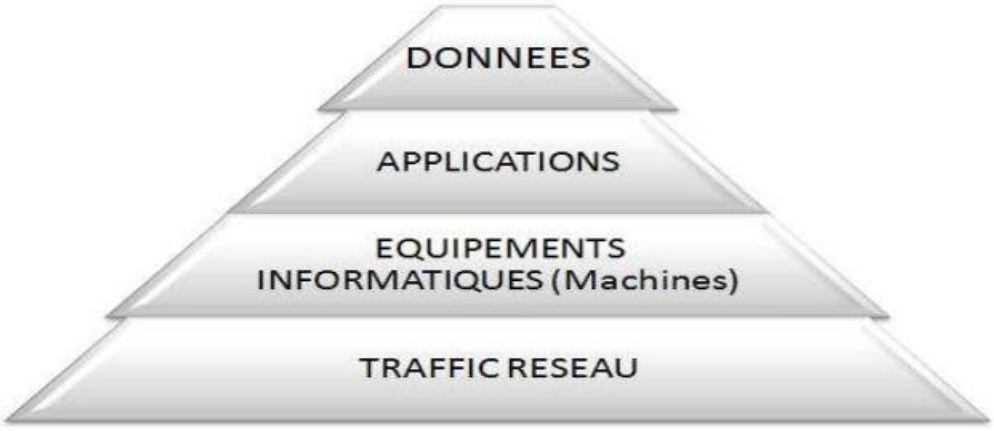
Test Pratique

Introduction

De nos jours, Le monde connaît des avancées très significatives dans le domaine informatique ; les besoins en matière de sécurité sont un peu plus impérieux, et la prédisposition n'est forcément pas à la baisse. Depuis quelques années déjà, on participe à un changement constant des techniques, qu'il s'agisse des techniques visant à sécuriser l'échange des données ou des techniques de mises au point pour contourner les systèmes sécurisés. D'où, la sécurité des données tend à s'améliorer. Et comme prône ce proverbe chinois : « *l'art de la guerre est basé sur la tromperie* », de même par analogie, la sécurité informatique doit représenter une stratégie qui éradique cette tromperie.

Il est sans ignorer que, le matériel informatique est quasiment partout. En effet, d'une part le matériel est accessibles à un prix très abordable, et d'autre part, les logiciels tendent à se simplifier et permettent une prise en main rapide.

En plus, les entreprises, informatisées, nécessitent un réseau sécurisé pour le transfert des données aussi bien entre les machines de ladite entreprise qu'avec des machines externes. Cela étant, la sécurité de façon générale est présente à plusieurs niveaux, qu'il s'agisse des différentes portées de l'information.



Module 1 : Introduction à la sécurité informatique

La sécurité informatique est un domaine crucial dans le contexte actuel de la technologie de l'information. Elle englobe un ensemble de mesures, de technologies et de bonnes pratiques visant à protéger les systèmes informatiques, les données et les réseaux contre les menaces et les attaques malveillantes. L'objectif principal est d'assurer la confidentialité, l'intégrité et la disponibilité des informations.

Module 2 : Les objectifs de la sécurité informatique



Confidentialité



Intégrité



Disponibilité



Authenticité



Non-répudiation

- ***La confidentialité*** est un ensemble de règles qui empêche la divulgation d'informations sensibles à des personnes, des ressources et des processus non autorisés. Les méthodes permettant de garantir la confidentialité comprennent le cryptage des données, la vérification de l'identité et l'authentification à deux facteurs.

- ***L'intégrité*** garantit que les informations ou les processus du système sont protégés contre toute modification intentionnelle ou accidentelle. L'utilisation d'une fonction de hachage ou d'une somme de contrôle est un moyen de garantir l'intégrité.

- ***La disponibilité*** signifie que les utilisateurs autorisés peuvent accéder aux systèmes et aux données quand et où ils en ont besoin et que ceux qui ne remplissent pas les conditions établies n'y ont pas accès. On peut y parvenir en entretenant l'équipement, en effectuant des réparations matérielles, en maintenant les systèmes d'exploitation et les logiciels à jour et en créant des sauvegardes.

- ***La non-répudiation*** signifie que la transaction ne peut être niée par aucun des correspondants. La non-répudiation de l'origine et de la réception des données prouve que les données ont bien été reçues. Cela se fait par le biais de certificats numériques grâce à une clé privée.

- **L'authentification -** Elle limite l'accès aux personnes autorisées. Il faut s'assurer de l'identité d'un utilisateur avant l'échange de données.

Modules 3 : Les champs d'application de la sécurité informatique

Les champs d'application de la sécurité informatique s'étendent à divers domaines afin de protéger les systèmes, les données et les utilisateurs contre des attaques malveillantes.

- *Sécurité des réseaux*
- *Sécurité des systèmes*
- *Sécurité des données*
- *Sécurité des applications*
- *Sécurité physique*
- *Sécurité Cloud*

3-1 Sécurité des Réseaux :

La sécurité des réseaux vise à protéger les données qui circulent à travers les réseaux informatiques contre les accès non autorisés, les interceptions et les altérations.

Quelques principes clés de la sécurité des réseaux incluent :

- *Firewalls* : Mise en place de pare-feu pour filtrer le trafic entrant et sortant.
- *VPN (Réseau Privé Virtuel)* : Utilisation de connexions sécurisées pour échanger des données sur des réseaux publics.
- *Sécurité Wi-Fi* : Configuration sécurisée des réseaux sans fil pour prévenir les intrusions.
- *Détection d'intrusion (IDS)* : Mise en place de systèmes de détection pour repérer les activités suspectes.
- *Mises à jour régulières* : Application des correctifs de sécurité pour les équipements réseau.

3-2 Sécurité des Systèmes :

La sécurité des systèmes vise à protéger les ordinateurs, serveurs et dispositifs informatiques contre les menaces telles que les logiciels malveillants, les virus et les attaques d'exploits.

Principaux aspects de la sécurité des systèmes :

- *Antivirus/Antimalware* : Utilisation de logiciels pour détecter et éliminer les programmes malveillants.
- *Mises à jour régulières* : Application des correctifs de sécurité pour les systèmes d'exploitation et les logiciels.
- *Politiques de mot de passe* : Mise en place de politiques robustes pour les mots de passe afin de renforcer l'authentification.
- *Contrôle d'accès* : Gestion des droits d'accès des utilisateurs pour limiter les autorisations.
- *Sauvegardes régulières* : Création de copies de sauvegarde pour la récupération en cas de perte de données.

3-3 Sécurité des Données :

La sécurité des données vise à protéger l'intégrité, la confidentialité et la disponibilité des informations stockées.

Principaux éléments de la sécurité des données :

- *Chiffrement :* Utilisation de techniques de chiffrement pour rendre les données illisibles aux personnes non autorisées.

- *Contrôle d'accès :* Gestion des droits d'accès aux données pour restreindre l'accès non autorisé.

- *Sauvegardes régulières* : Création de copies de sauvegarde pour prévenir la perte de données.

- *Gestion des identités* : Contrôle des accès basé sur l'identité des utilisateurs.

- *Formation des employés* : Sensibilisation des employés à la protection des données et à la prévention des fuites d'informations.

3-4 Sécurité des Applications :

La sécurité des applications vise à garantir que les logiciels développés et utilisés sont exempts de vulnérabilités.

Mesures clés de sécurité des applications :

- *Tests de sécurité* : Réalisation de tests de sécurité pour identifier les vulnérabilités.

- *Mises à jour régulières :* Application des correctifs de sécurité pour les applications.

- *Gestion des vulnérabilités* : Correction proactive des faiblesses identifiées dans le code.

- *Authentification et autorisation* : Mise en place de mécanismes robustes pour l'authentification des utilisateurs et l'autorisation d'accès.

- *Contrôle des accès* : Limitation des autorisations d'accès aux fonctionnalités critiques.

3-5 Sécurité Physique :

La sécurité physique concerne la protection des équipements matériels et des locaux contre les menaces physiques.

Principales mesures de sécurité physique :

- *Contrôle d'accès physique* : Utilisation de cartes d'accès, de serrures électroniques, etc.
- *Surveillance vidéo* : Utilisation de caméras de sécurité pour la surveillance des locaux.
- *Systèmes d'alarme* : Mise en place d'alarmes en cas d'intrusion ou d'activité suspecte.
- *Sauvegardes hors site* : Stockage de copies de sauvegarde dans des emplacements externes sécurisés.
- *Formation des employés* : Sensibilisation du personnel à la sécurité physique et aux procédures d'urgence.

3-6 Sécurité Cloud :

Avec le passage croissant vers des services basés sur le cloud, la sécurité cloud est devenue essentielle. Elle se concentre sur la protection des données stockées dans le cloud, la gestion des accès et la sécurisation des services cloud.

Modules 4 : Terminologie de la securité informatique

La sécurité informatique est un domaine crucial dans le paysage technologique moderne, visant à protéger les systèmes informatiques, les données, et les réseaux contre les menaces potentielles. Pour comprendre ce domaine complexe, il est essentiel de maîtriser les terminologies clés associées à la sécurité informatique.

- ***Cybersécurité***

La cybersécurité englobe l'ensemble des pratiques, technologies et processus conçus pour protéger les systèmes informatiques, les réseaux et les données contre les attaques, les dommages, l'accès non autorisé, et autres menaces potentielles.

- ***Firewall (pare-feu)***

Un pare-feu est un dispositif de sécurité, matériel ou logiciel, qui surveille et contrôle le trafic réseau entre un réseau privé et un réseau public (comme Internet). Son rôle principal est de filtrer le trafic en autorisant ou en bloquant certains paquets de données en fonction de règles de sécurité prédéfinies. Les pares-feux contribuent à protéger les réseaux contre les accès non autorisés, les attaques malveillantes et les intrusions.

- ***Antivirus***

Un antivirus est un logiciel conçu pour détecter, prévenir et éliminer les logiciels malveillants, tels que les virus, les vers, les chevaux de Troie et les spywares. Il analyse les fichiers et les programmes à la recherche de signatures ou de comportements suspects, puis prend des mesures pour mettre en quarantaine ou supprimer les menaces détectées. Les antivirus jouent un rôle essentiel dans la protection des systèmes informatiques contre les infections par des logiciels malveillants.

- ***Cryptographie***

La cryptographie est l'art de protéger des informations en les rendant illisibles pour des personnes non autorisées. Elle utilise des algorithmes mathématiques pour chiffrer des données, les transformant en un format incompréhensible sans la clé de déchiffrement appropriée. La cryptographie est largement utilisée dans la sécurité informatique pour garantir la confidentialité des communications, l'intégrité des données et l'authenticité des parties impliquées.

- ***Authentification***

L'authentification est le processus de vérification de l'identité d'un utilisateur, d'un système ou d'une entité. Elle vise à garantir que la personne ou le dispositif prétendant être une entité spécifique est effectivement celle-ci. Les méthodes d'authentification incluent l'utilisation de mots de passe, d'empreintes digitales, de cartes à puce, de codes PIN, ou une combinaison de ces éléments, en fonction du niveau de sécurité requis.

- ***Intrusion***

Une intrusion se produit lorsqu'une personne non autorisée ou un programme malveillant pénètre dans un système informatique, un réseau ou une application, contournant ainsi les mécanismes de sécurité en place. Les intrusions peuvent être classées comme des attaques visant à compromettre la confidentialité, l'intégrité ou la disponibilité des informations. Les systèmes de détection d'intrusion sont utilisés pour détecter et prévenir de telles activités.

- ***Vulnérabilité***

Une vulnérabilité désigne une faiblesse ou une faille dans un système, une application ou un réseau qui peut être exploitée par des individus malveillants pour compromettre la sécurité. Les vulnérabilités peuvent résulter de défauts de conception, de programmation ou de configuration. La gestion des vulnérabilités implique l'identification, l'évaluation et la correction proactive de ces faiblesses pour renforcer la sécurité globale d'un système.

- ***Attaque par force brute***

Une attaque par force brute est une méthode où un attaquant tente de découvrir un mot de passe ou une clé en essayant systématiquement toutes les combinaisons possibles jusqu'à ce qu'il trouve la bonne.

- ***Hameçonnage (Phishing)***

L'hameçonnage est une technique d'attaque où les cybercriminels utilisent des faux e-mails, sites web ou messages pour tromper les utilisateurs et les inciter à divulguer des informations personnelles, telles que des mots de passe ou des informations financières.

Modules 5 : Types d’attaques

5-1 Attaques par Force Brute

Les attaques par force brute sont des tentatives répétées et systématiques visant à découvrir un mot de passe, une clé de chiffrement ou une autre information secrète en essayant différentes combinaisons de manière exhaustive.

Les attaquants utilisent des programmes automatisés qui génèrent de manière itérative toutes les possibilités jusqu'à ce qu'ils trouvent la bonne clé. Pour se protéger contre ces attaques, les organisations mettent souvent en place des politiques de mot de passe robustes, limitent le nombre de tentatives d'authentification et utilisent des mécanismes de verrouillage des comptes après un certain nombre d'échecs.

5-2 Phishing :

Le phishing est une technique d'attaque sociale qui vise à tromper les utilisateurs en les incitant à divulguer des informations sensibles telles que des identifiants de connexion, des mots de passe ou des informations financières.

Les attaquants utilisent souvent des e-mails, des messages instantanés ou des sites web frauduleux qui imitent des entités légitimes pour inciter les utilisateurs à fournir leurs informations. Le phishing peut également impliquer des appels téléphoniques ou d'autres formes de communication.

Les utilisateurs sont généralement incités à cliquer sur des liens malveillants ou à télécharger des pièces jointes infectées. Pour se protéger contre le phishing, il est essentiel d'éduquer les utilisateurs sur la reconnaissance des tentatives de phishing, d'utiliser des filtres anti-phishing et d'adopter des pratiques de sécurité rigoureuses.

5-3 Malware

Les cybercriminels utilisent de nombreux types de ***MALWARE*** pour mener à bien leurs activités. Les logiciels malveillants sont des codes qui peuvent être utilisés pour voler des données, contourner les contrôles d'accès, endommager ou compromettre un système. Il est essentiel de connaître les différents types de logiciels malveillants et leur mode de propagation pour pouvoir les contenir et les supprimer.

- ***Spyware :*** Conçus pour vous suivre et vous espionner, les logiciels espions surveillent votre activité en ligne et peuvent enregistrer chaque touche que vous appuyez sur votre clavier, ainsi que capturer la quasi-totalité de vos données, y compris des informations personnelles sensibles telles que vos coordonnées bancaires en ligne. Les spywares modifient les paramètres de sécurité de vos appareils.

Ils s'intègrent souvent à des logiciels légitimes ou à des chevaux de Troie.

- ***Adware*** : Les logiciels publicitaires (adware) sont souvent installés avec certaines versions de logiciels et sont conçus pour diffuser automatiquement des publicités à l'utilisateur, le plus souvent sur un navigateur web. Vous le savez quand vous le voyez. Il est difficile de l'ignorer lorsque vous êtes confronté à des fenêtres publicitaires qui s'affichent constamment à l'écran.

Il est fréquent que les logiciels publicitaires soient accompagnés de logiciels espions.

- ***Backdoor :*** Ce type de ***Malware*** est utilisé pour obtenir un accès non autorisé en contournant les procédures d'authentification normales pour accéder à un système. Les pirates peuvent ainsi accéder à distance aux ressources d'une application et lancer des commandes à distance.

Un Backdoor fonctionne en arrière-plan et est difficile à détecter.

- ***Ransomware*** : Ce logiciel malveillant est conçu pour garder captif un système informatique ou les données qu'il contient jusqu'à ce qu'un paiement soit effectué. Le ransomware fonctionne généralement en chiffrant vos données de manière à ce que vous ne puissiez pas y accéder.

Certaines versions de ransomware peuvent tirer parti de vulnérabilités spécifiques du système pour le verrouiller. Les *ransomwares* se propagent souvent par le biais de courriels d'hameçonnage qui vous encouragent à télécharger une pièce jointe malveillante ou par le biais d'une vulnérabilité logicielle.

- ***Scareware :*** Il s'agit d'un type de logiciel malveillant qui utilise des tactiques d'effarouchement pour vous inciter à effectuer une action spécifique. Les scareware consistent principalement en des fenêtres de type système d'exploitation qui s'affichent pour vous avertir que votre système est en danger et qu'il doit exécuter un programme spécifique pour revenir à un fonctionnement normal.

Si vous acceptez d'exécuter le programme en question, votre système sera infecté par un logiciel malveillant.

- ***Rootkit*** : Ce logiciel malveillant est conçu pour modifier le système d'exploitation afin de créer une porte dérobée, que les attaquants peuvent ensuite utiliser pour accéder à votre ordinateur à distance. La plupart des *rootkits* tirent parti de vulnérabilités logicielles pour accéder à des ressources qui ne devraient normalement pas être accessibles (escalade des privilèges) et modifier les fichiers du système.

Les rootkits peuvent également modifier les outils d'analyse et de surveillance du système, ce qui les rend très difficiles à détecter. Dans la plupart des cas, un ordinateur infecté par un rootkit doit être effacé et tous les logiciels nécessaires réinstallés.

- ***Virus :*** Un virus est un type de programme informatique qui, lorsqu'il est exécuté, se réplique et s'attache à d'autres fichiers exécutables, comme un document, en y insérant son propre code. La plupart des virus nécessitent l'interaction de l'utilisateur final pour être activés et peuvent être écrits pour agir à une date ou une heure spécifique.

Les virus peuvent être relativement inoffensifs, comme ceux qui affichent une image amusante. Ils peuvent aussi être destructeurs, comme ceux qui modifient ou suppriment des données.

Les virus peuvent également être programmés pour muter afin d'éviter d'être détectés. La plupart des virus se propagent par le biais de clés USB, de disques optiques, de partages de réseau ou de courriers électroniques.

- ***Trojan horse :*** Ce logiciel malveillant effectue des opérations malveillantes en masquant sa véritable intention. Il peut sembler légitime, mais il est en fait très dangereux. Les chevaux de Troie exploitent vos privilèges d'utilisateur et se trouvent le plus souvent dans des fichiers images, des fichiers audios ou des jeux.

Contrairement aux virus, les chevaux de Troie ne se reproduisent pas d'eux-mêmes, mais agissent comme un leurre pour faire passer des logiciels malveillants à des utilisateurs qui ne se doutent de rien.

- ***Worms :*** Il s'agit d'un type de logiciel malveillant qui se reproduit afin de se propager d'un ordinateur à l'autre. Contrairement à un virus, qui nécessite un programme hôte pour fonctionner, les vers peuvent fonctionner seuls. Outre l'infection initiale de l'hôte, ils ne nécessitent pas la participation de l'utilisateur et peuvent se propager très rapidement sur le réseau.

Les vers (worms) présentent des caractéristiques similaires : Ils exploitent les vulnérabilités du système, ils ont un moyen de se propager et ils contiennent tous un code malveillant (charge utile) pour endommager les systèmes informatiques ou les réseaux.

PS : Les vers sont responsables de certaines des attaques les plus dévastatrices sur l'internet. En 2001, le ver **Code Red** a infecté plus de 300 000 serveurs en seulement 19 heures.

5-4 Déni de service (DDoS)

Denial-of-Service : Les attaques par déni de service (DoS) sont un type d'attaque de réseau relativement simple à réaliser, même par un attaquant non qualifié. Une attaque par déni de service entraîne une sorte d'interruption du service réseau pour les utilisateurs, les appareils ou les applications.

Exemple :

- ***Quantité excessive de trafic :*** C'est le cas lorsqu'un réseau, un hôte ou une application reçoit une énorme quantité de données à un rythme qu'il ne peut pas gérer. Cela entraîne un ralentissement de la transmission ou de la réponse, ou le blocage de l'appareil ou du service.

- ***Paquets formatés de manière malveillante :*** Un paquet est un ensemble de données qui circulent entre un ordinateur ou une application source et un récepteur sur un réseau, tel que l'internet. Lorsqu'un paquet formaté de manière malveillante est envoyé, le destinataire est incapable de le traiter.

IMPORTANT : Les attaques par déni de service sont considérées comme un risque majeur car elles peuvent facilement interrompre les communications et entraîner des pertes de temps et d'argent considérables.

- ***Distributed Dos :*** Une attaque DDoS est similaire à une attaque DoS mais provient de sources multiples et coordonnées. Par exemple, un attaquant construit un réseau (botnet) d'hôtes infectés appelés zombies :

  - Un attaquant construit un réseau (botnet) d'hôtes infectés appelés zombies, qui sont contrôlés par des systèmes manipulateurs.
  - Les ordinateurs zombies vont constamment scanner et infecter d'autres hôtes, créant ainsi de plus en plus de zombies.
  - Lorsqu'il est prêt, le pirate ordonne aux systèmes de gestion de faire en sorte que le botnet de zombies exécute une attaque DDoS.

5-5 Botnet

Un ordinateur zombie est généralement infecté par la visite d'un site web dangereux ou par l'ouverture d'une pièce jointe ou d'un fichier multimédia infecté. Un réseau de robots est un groupe de robots, connectés via l'internet, qui peut être contrôlé par un individu ou un groupe malveillant. Il peut compter des dizaines de milliers, voire des centaines de milliers de bots qui sont généralement contrôlés par un serveur de commande et de contrôle.

Ces bots peuvent être activés pour distribuer des logiciels malveillants, lancer des attaques DDoS, distribuer des courriers électroniques non sollicités ou exécuter des attaques par force brute sur des mots de passe. Les cybercriminels louent souvent des réseaux de robots à des tiers à des fins malveillantes.

5-6 Social engineering

L'ingénierie sociale consiste à manipuler les gens pour qu'ils accomplissent des actions ou divulguent des informations confidentielles. Les ingénieurs sociaux s'appuient souvent sur la volonté des gens d'être utiles, mais ils exploitent également leurs faiblesses. Par exemple, un pirate appellera un employé autorisé pour lui présenter un problème urgent nécessitant un accès immédiat au réseau et fera appel à la vanité ou à l'avidité de l'employé ou invoquera son autorité en utilisant des techniques de dénonciation afin d'obtenir cet accès.

Exemple :

- ***Prétextat :*** Il s'agit du fait qu'un pirate appelle une personne et lui ment pour tenter d'accéder à des données privilégiées. Il prétend avoir besoin des données personnelles ou financières d'une personne pour confirmer son identité.

- ***La filature :*** Il s'agit du cas où un attaquant suit rapidement une personne autorisée dans un lieu physique sécurisé

Modules 6 : Profils et Capacités des attaquants

Examinons quelques-uns des principaux types de cyber attaquants qui sont prêts à tout pour mettre la main sur nos informations. Ils sont souvent classés en trois catégories : ***White Hat, Gray Hat ou Black Hat***

- ***Amateurs :*** Le terme "script kiddies" est apparu dans les années 1990 et désigne les pirates amateurs ou inexpérimentés qui utilisent des outils existants ou des instructions trouvées sur l'internet pour lancer des attaques. Certains script kiddies sont simplement curieux, d'autres essaient de démontrer leurs compétences et de nuire. Même si les script kiddies utilisent des outils de base, leurs attaques peuvent avoir des conséquences dévastatrices.

- ***Pirates informatiques (Hacker) :*** Ce groupe d'attaquants s'introduit dans les systèmes ou réseaux informatiques pour y accéder. En fonction de l'intention de leur intrusion, ils peuvent être classés comme des ***White Hat, Gray Hat ou Black Hat***

    - Les pirates de type ***"White Hat"*** s'introduisent dans des réseaux ou des systèmes informatiques afin d'en identifier les faiblesses et d'améliorer ainsi la sécurité d'un système ou d'un réseau. Ces intrusions sont effectuées avec une autorisation préalable et les résultats sont communiqués au propriétaire.

    - Les ***"Gray Hat"*** peuvent chercher à trouver des failles dans un système, mais ils ne communiqueront leurs résultats aux propriétaires du système que si cela coïncide avec leurs objectifs. Ils peuvent même publier les détails de la vulnérabilité sur l'internet afin que d'autres attaquants puissent l'exploiter.

    - Les ***"Black Hat"*** tirent parti de toute vulnérabilité à des fins personnelles, financières ou politiques illégales.

- ***Pirates informatiques organisés :***

Ces attaquants comprennent les organisations de cybercriminels, les hacktivistes, les terroristes et les pirates informatiques parrainés par l'État. Ils sont généralement très sophistiqués et organisés, et peuvent même fournir des services de cybercriminalité à d'autres criminels.

Les hacktivistes font des déclarations politiques pour sensibiliser le public à des questions qui leur tiennent à cœur.

Les attaquants parrainés par un État recueillent des renseignements ou commettent des actes de sabotage pour le compte de leur gouvernement. Ils sont généralement très bien formés et bien financés, et leurs attaques sont axées sur des objectifs spécifiques qui profitent à leur gouvernement.

Modules 7 : Services principaux de la securité informatique

La sécurité informatique repose sur un ensemble de services essentiels visant à protéger les systèmes, les réseaux et les données contre les menaces numériques croissantes. Ces services sont conçus pour anticiper, détecter, répondre et atténuer les risques de sécurité.

Dans cette introduction, nous explorerons les services principaux de la sécurité informatique qui jouent un rôle central dans la préservation de l'intégrité, de la confidentialité et de la disponibilité des informations numériques.

- *Audit de Sécurité*
- *Gestion des identités et des accès (IAM)*
- *Sécurité des applications web*
- *Surveillance et détection des menaces*
- *Gestion des vulnérabilités*
- *Sauvegarde et récupération*
- *Planification et Réponse aux Incidents*

7-1 Audit et Sécurité :

L'audit de sécurité constitue le fondement de toute stratégie de protection. Il implique l'évaluation exhaustive des systèmes, des réseaux et des applications pour identifier les vulnérabilités potentielles. Les audits de sécurité permettent de comprendre les points faibles et de prendre des mesures préventives pour renforcer la résilience des infrastructures.

7-2 Gestion des Identités et des Accès (IAM) **:**

La gestion des identités et des accès (IAM) est un ensemble de processus et de technologies visant à garantir que seules les personnes autorisées ont accès aux ressources informatiques d'une organisation. Cela englobe la création, la gestion et la révocation des identités d'utilisateurs, ainsi que la définition et la gestion des droits d'accès associés. IAM contribue à renforcer la sécurité en assurant une authentification et une autorisation appropriées.

7-3 Sécurité des Applications Web :

La sécurité des applications web vise à protéger les applications accessibles via un navigateur web contre les attaques et les vulnérabilités. Cela inclut la protection contre les attaques par injection (comme les injections SQL), les attaques de contournement d'authentification, la validation insuffisante, la gestion des sessions, et d'autres vulnérabilités spécifiques aux applications web. Les pratiques de sécurité des applications web comprennent la validation des entrées, la gestion des sessions sécurisées et l'utilisation de pare-feu applicatifs.

7-4 Surveillance et Détection des Menaces :

La surveillance et la détection des menaces consistent à surveiller en temps réel les activités sur les réseaux, les systèmes et les applications pour identifier les comportements suspects ou les signes d'attaques. Cela implique l'utilisation de systèmes de détection d'intrusion, d'analyse des journaux (log), de surveillance du trafic réseau, et d'autres outils pour détecter les anomalies et les activités malveillantes. La réponse rapide aux menaces détectées permet de minimiser les risques et d'atténuer les dommages potentiels.

7-5 Gestion des Vulnérabilités :

La gestion des vulnérabilités est le processus de recherche, d'évaluation et de correction des faiblesses dans les systèmes, les réseaux et les applications. Cela implique la réalisation d'analyses de vulnérabilité, l'utilisation de scanners de sécurité, et la mise en œuvre de correctifs pour remédier aux vulnérabilités identifiées. La gestion proactive des vulnérabilités contribue à renforcer la sécurité en prévenant les attaques exploitant ces faiblesses.

7-6 Sauvegarde et Récupération :

La sauvegarde et la récupération consistent à créer des copies de sauvegarde des données critiques et à mettre en place des plans de récupération après sinistre pour assurer la continuité des opérations en cas de perte de données ou d'incidents graves. Les stratégies de sauvegarde comprennent la planification régulière de sauvegardes, la validation des sauvegardes, et la mise en place de procédures de restauration rapides. Ces mesures garantissent la disponibilité et l'intégrité des données même en cas d'incidents majeurs.

7-7 Planification et Réponse aux Incidents :

Les services de planification et de réponse aux incidents préparent les organisations à faire face aux attaques. Cela inclut l'élaboration de plans d'intervention, la formation des équipes de sécurité et la mise en place de procédures pour minimiser les dommages en cas d'incident.

Modules 8 : Hacking Ethique

Le hacking éthique implique l'utilisation légale et autorisée de compétences en piratage pour identifier et corriger les vulnérabilités dans les systèmes. Les professionnels du ‘’hacking éthique’’, également appelés "hackers éthiques" ou "pentesters", sont engagés pour renforcer la sécurité des systèmes et des réseaux plutôt que pour exploiter des faiblesses à des fins malveillantes.

C'est une pratique responsable visant à améliorer la résilience des systèmes face aux menaces potentielles.

Objectifs :

- Pour se prémunir contre les hackers malveillants face à leurs tentatives d’accès au système
- Pour découvrir des vulnérabilités
- Pour renforcer la sécurité d’une organisation
- Pour garantir la protection des données
- Pour éviter les violations de sécurité

Terminologies utilisées

- Hack Value : notion pour exprimer que quelque chose vaut la peine d’être fait ou est intéressant.

- Vulnerability : failles, erreur d’implémentation ou de configuration pouvant être utilisés pour atteindre des cibles.

- Exploit : notion pour exprimer une brèche de la sécurité d’un système informatique.

- Payload : c’est une partie d’un code malveillant qui est utilisé pour faire une Attaque

- Zero-day-attack : désigne une attaque basée sur une vulnérabilité d’une application dont l’éditeur n’a pas encore connaissance ou n’a pas encore trouvé de solution corrective.

- Daisy Chaining : C’est le fait d’accéder à un réseau ou à un ordinateur et l’utiliser pour prendre possession d’autres réseaux

- Doxing : C’est le fait de publier des informations personnelles à propos d’un individu.

Les Phases du Hacking Ethique



Conclusion

En conclusion, la sécurité informatique revêt une importance cruciale dans un monde de plus en plus dépendant de la technologie de l'information. Elle englobe un ensemble de pratiques, de technologies et de stratégies visant à protéger les systèmes, les réseaux et les données contre les menaces potentielles et les attaques malveillantes. Les objectifs fondamentaux de la sécurité informatique, tels que la confidentialité, l'intégrité et la disponibilité des informations, nécessitent une approche holistique et proactive.

Les champs d'application de la sécurité informatique sont divers, allant de la protection des réseaux et des systèmes à la sécurisation des données sensibles, des applications et même des aspects physiques des infrastructures informatiques. La terminologie associée à la sécurité informatique, des pares-feux à la cryptographie en passant par l'authentification, reflète la complexité et la diversité des défis auxquels les professionnels de la sécurité sont confrontés.

Les types d'attaques, tels que les attaques par force brute et le phishing, soulignent la variété des menaces auxquelles les systèmes sont exposés. Comprendre les profils et les capacités des attaquants permet de mieux anticiper et contrer ces menaces. Les services principaux de sécurité informatique, tels que la gestion des identités et des accès, la surveillance des menaces, et la gestion des vulnérabilités, constituent des piliers essentiels pour maintenir un niveau de sécurité robuste.

Enfin, le hacking éthique émerge comme une approche responsable visant à renforcer la sécurité en identifiant et corrigeant les vulnérabilités de manière légale. La sécurité informatique est un défi en constante évolution, nécessitant une adaptation continue aux nouvelles menaces et l'adoption de meilleures pratiques pour assurer la résilience des systèmes face aux attaques toujours plus sophistiquées. En investissant dans la sensibilisation, la formation et la mise en œuvre de technologies de pointe, les organisations peuvent mieux se préparer à faire face aux défis complexes de la sécurité informatique.